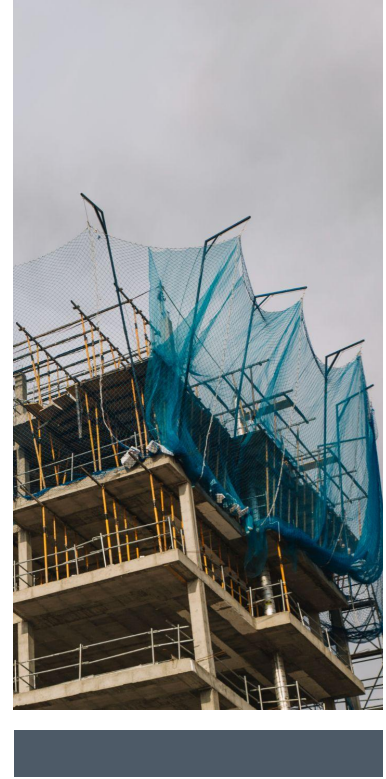
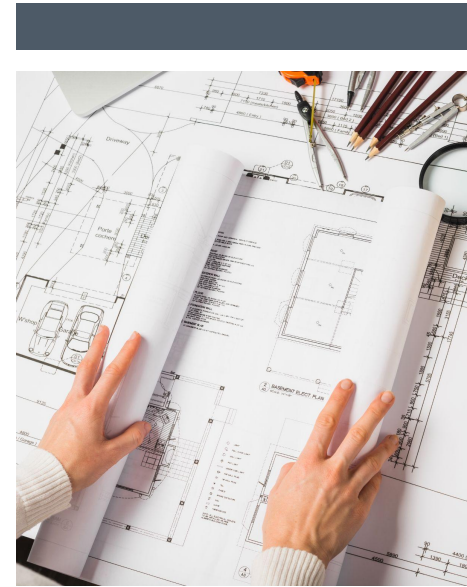


Software Security and Privacy

Software Engineering Course – 9
2025-2026



Security of a Software Product

Figure 7.1 Types of security threat

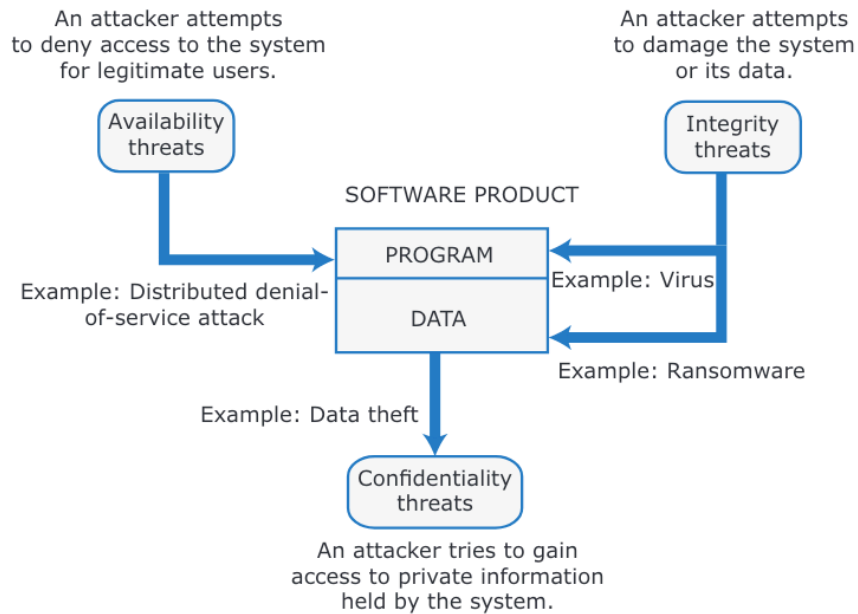
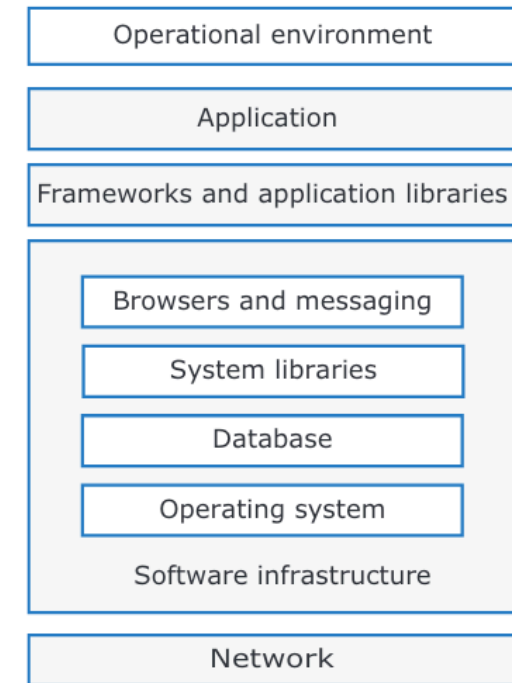


Figure 7.2 System infrastructure stack



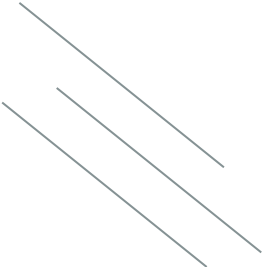


Injection attacks

Attacks & Defences

```
accNum = getAccountNumber ()  
SQLstat = "SELECT * FROM AccountHolders WHERE accountnumber = '"  
+ accNum + "';"  
database.execute (SQLstat)
```

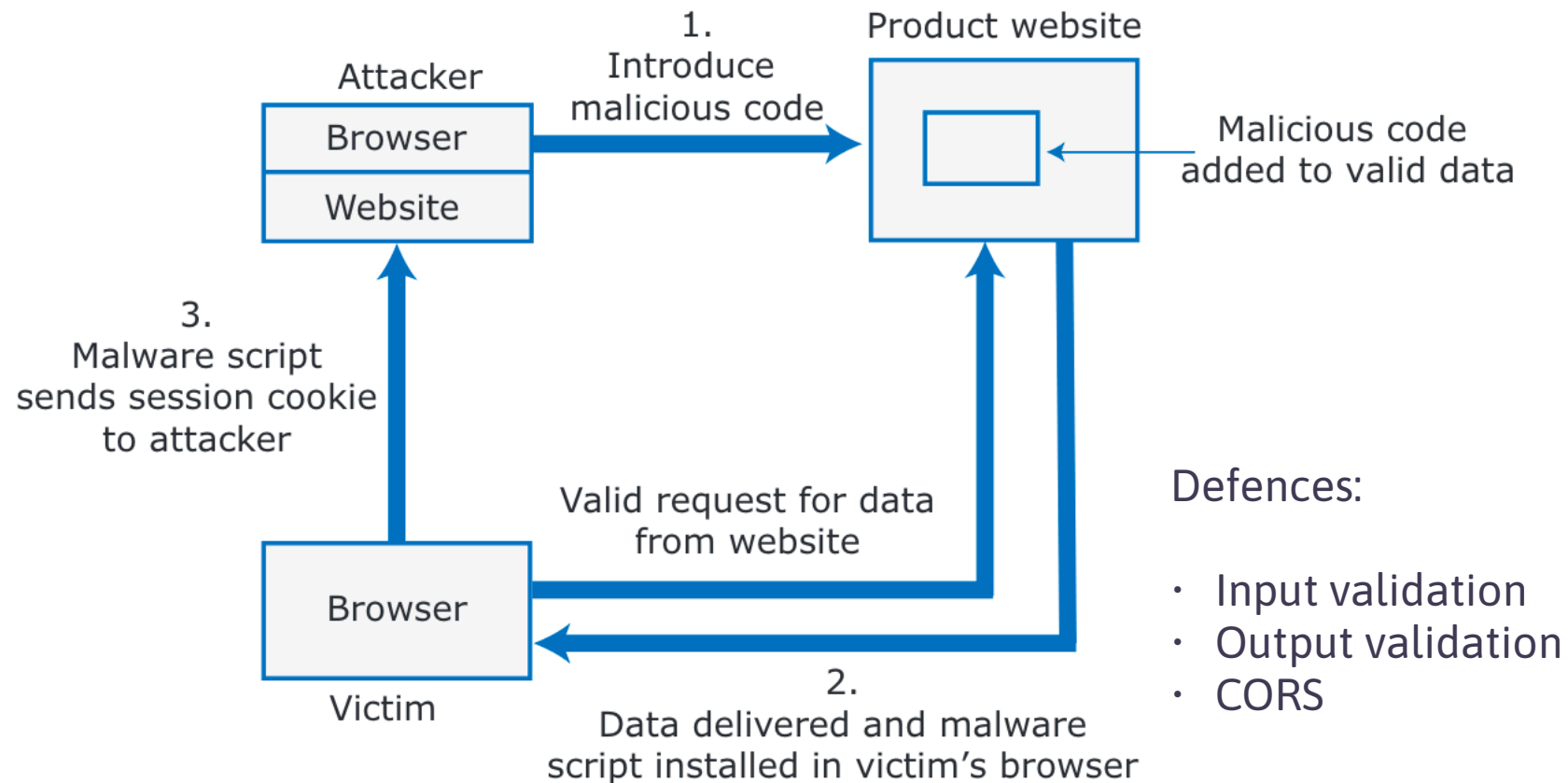
```
SELECT * from AccountHolders WHERE accountnumber = '10010010' OR '1' = '1';
```



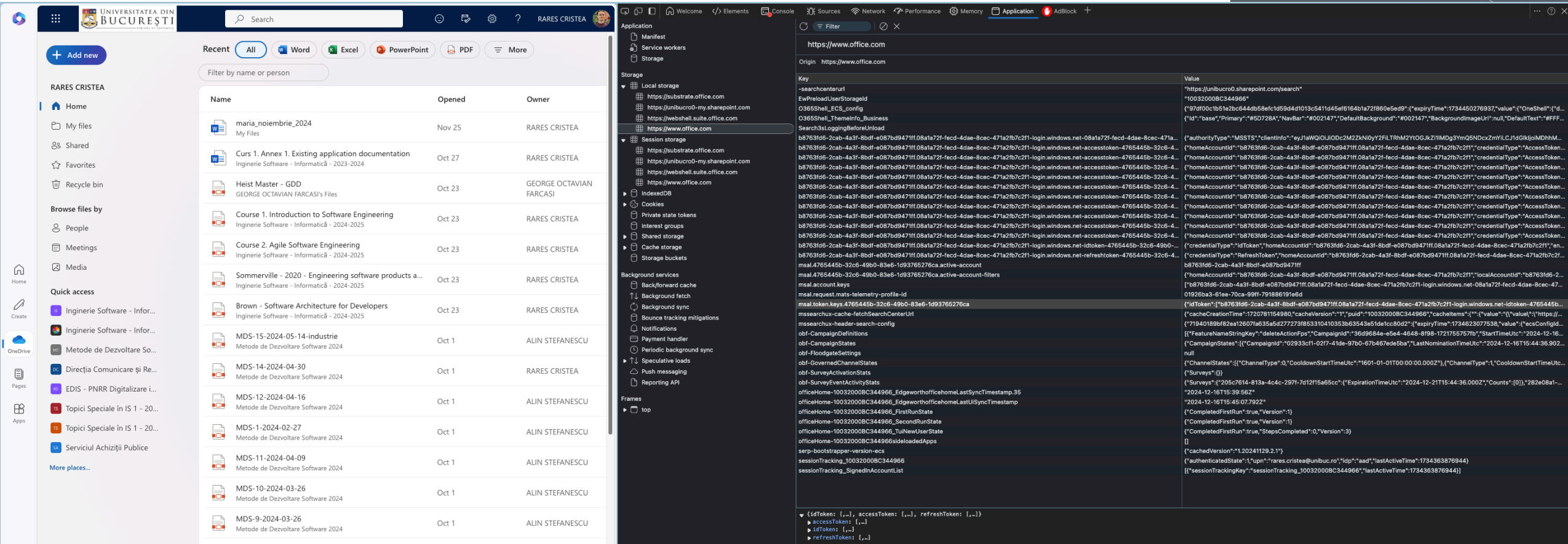
Cross-site Scripting (XSS)

Attacks & Defences

Figure 7.3 Cross-site scripting attack



Session Hijacking Attack



The screenshot illustrates a session hijacking attack on a web application. The browser window shows a file management interface for 'RARES CRISTEA' with a list of files and folders. The address bar shows 'https://www.office.com'. The developer tools console shows a list of cookies, including 'searchcenterurl', 'EwPreloadUserStorageId', 'O365Shell_ECS_config', 'O365Shell_ThemeInfo_Business', and 'Search3sLoggingBeforeUnload'. The 'Cookies' tab is selected, showing a list of cookies with their names, values, and expiration dates.

Name	Opened	Owner
maria_noiembrie_2024	Nov 25	RARES CRISTEA
Curs 1. Annex 1. Existing application documentation	Oct 27	RARES CRISTEA
Heist Master - GDD	Oct 23	GEORGE OCTAVIAN FARCASI
Course 1. Introduction to Software Engineering	Oct 23	RARES CRISTEA
Course 2. Agile Software Engineering	Oct 23	RARES CRISTEA
Sommerville - 2020 - Engineering software products a...	Oct 23	RARES CRISTEA
Brown - Software Architecture for Developers	Oct 23	RARES CRISTEA
MDS-15-2024-05-14-industrie	Oct 1	ALIN STEFANESCU
MDS-14-2024-04-30	Oct 1	RARES CRISTEA
MDS-12-2024-04-16	Oct 1	ALIN STEFANESCU
MDS-1-2024-02-27	Oct 1	ALIN STEFANESCU
MDS-11-2024-04-09	Oct 1	ALIN STEFANESCU
MDS-10-2024-03-26	Oct 1	ALIN STEFANESCU
MDS-9-2024-03-26	Oct 1	ALIN STEFANESCU

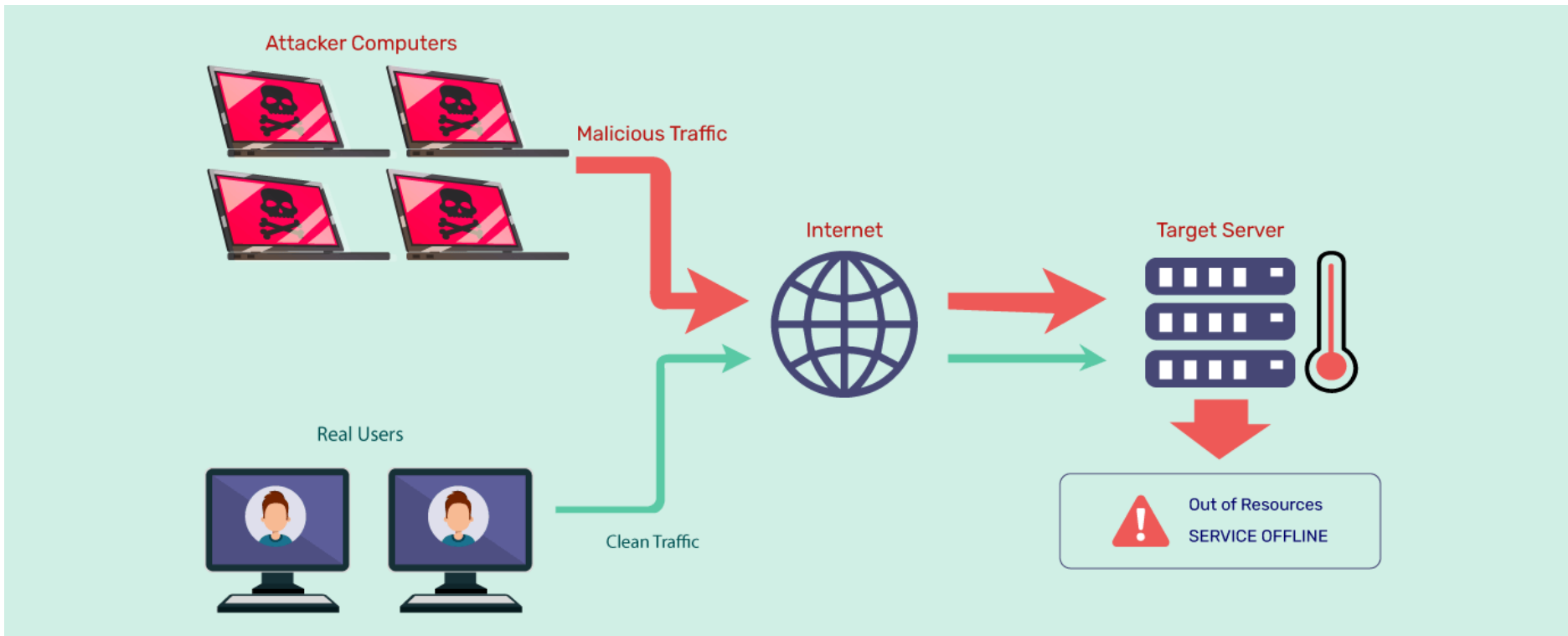
The developer tools console shows a list of cookies, including 'searchcenterurl', 'EwPreloadUserStorageId', 'O365Shell_ECS_config', 'O365Shell_ThemeInfo_Business', and 'Search3sLoggingBeforeUnload'. The 'Cookies' tab is selected, showing a list of cookies with their names, values, and expiration dates.

```
Key: searchcenterurl, Value: ~searchcenterurl
Key: EwPreloadUserStorageId, Value: EwPreloadUserStorageId
Key: O365Shell_ECS_config, Value: O365Shell_ECS_config
Key: O365Shell_ThemeInfo_Business, Value: O365Shell_ThemeInfo_Business
Key: Search3sLoggingBeforeUnload, Value: Search3sLoggingBeforeUnload
```

5. Attacker hijacks the user's session

DDoS

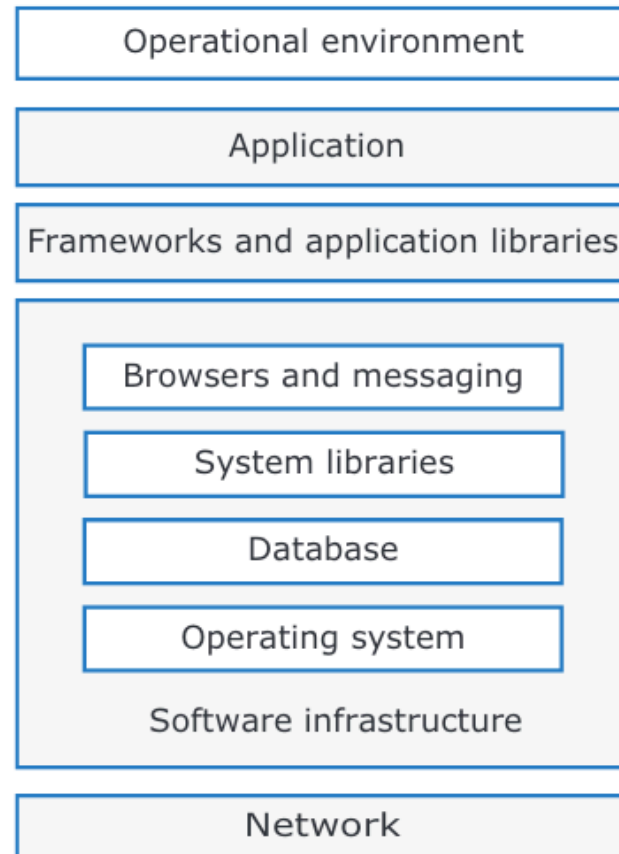
Attacks & Defences



DDoS

Attacks & Defences

Figure 7.2 System infrastructure stack



Defences:

- Temporary lockouts
- IP address tracking (and denial)

DDoS

Attacks & Defences

Hackers Flood NPM with Bogus Packages Causing a DoS Attack

📅 Apr 10, 2023 👤 Ravie Lakshmanan

Software Security / JavaScript



Threat actors flooded the npm open source package repository for Node.js with bogus packages that briefly even resulted in a denial-of-service (DoS) attack.

"The threat actors create malicious websites and publish empty packages with links to those malicious websites, taking advantage of open-source ecosystems' good reputation on search engines," Checkmarx's Jossef Harush Kadouri [said](#) in a report published last week.

"The attacks caused a denial-of-service (DoS) that made NPM unstable with sporadic 'Service Unavailable' errors."

While [similar campaigns](#) were recently observed propagating phishing links, the latest wave pushed the number of package versions to 1.42 million, a dramatic uptick from the approximate 800,000 packages released on npm.

10 Ways Zero Trust Defends Against Ransomware

Detect never-before-seen techniques, and protect users and devices wherever they are.

A person wearing glasses and a white shirt is looking at a laptop screen. The screen displays a blue and white security-themed graphic with a lock icon.

EBOOK

GET THE EBOOK

The Zscaler logo, consisting of a stylized 'z' in a blue circle followed by the word 'zscaler' in a sans-serif font.

The attack technique leverages the fact that open source repositories are ranked higher on search engine results to create rogue websites and upload empty npm modules with links to those sites in the README.md files.

The WINGsecurity logo, featuring the word 'WING' in a stylized font with a small 'security' tag.

Is there a **cyber risk** lurking in your SaaS stack?

Get a [free](#) risk assessment today.

The VONSH SECURITY logo, featuring the word 'VONSH' in a stylized font with 'SECURITY' below it.

WE MAKE NETWORK PENTESTING EASY.

The #1 Network Penetration Testing Platform for IT Teams

[BOOK A DEMO](#)

— Trending News



Protecting Tomorrow's World: Shaping the Cyber-Physical Future



Ongoing Phishing and Malware Campaigns in December 2024



SaaS Budget Planning Guide for IT Professionals



Microsoft MFA AuthQuake Flaw Enabled Unlimited Brute-Force Attempts Without Alerts



The Future of Network Security: Automated Internal and External

Dependency Confusion Attack

Attacks & Defences

Dependency Confusion: How I Hacked Into Apple, Microsoft and Dozens of Other Companies

The Story of a Novel Supply Chain Attack



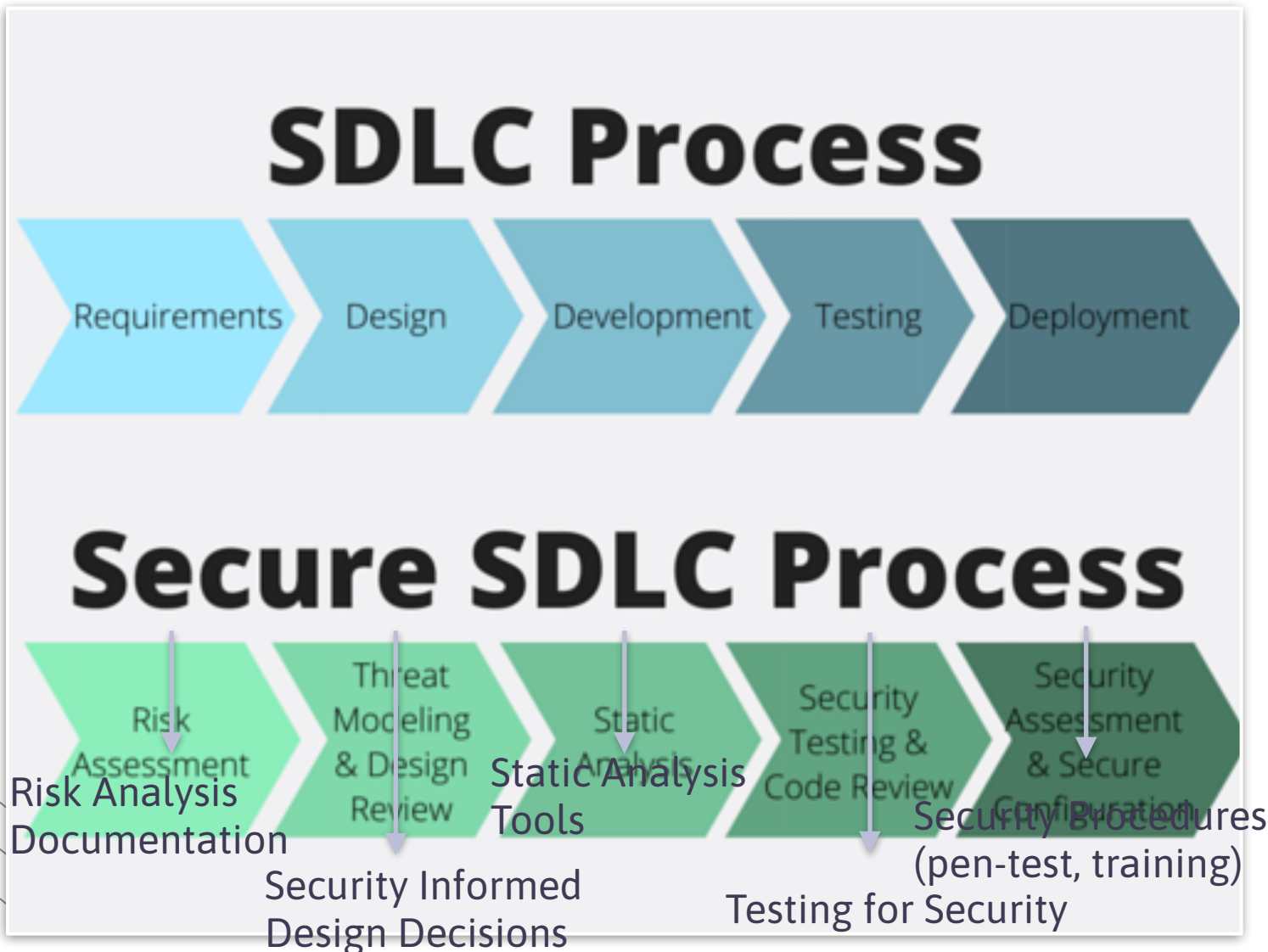
Alex Birsan · Follow

11 min read · Feb 9, 2021

20K 52



Security in the Software Development Lifecycle





Authentication ...



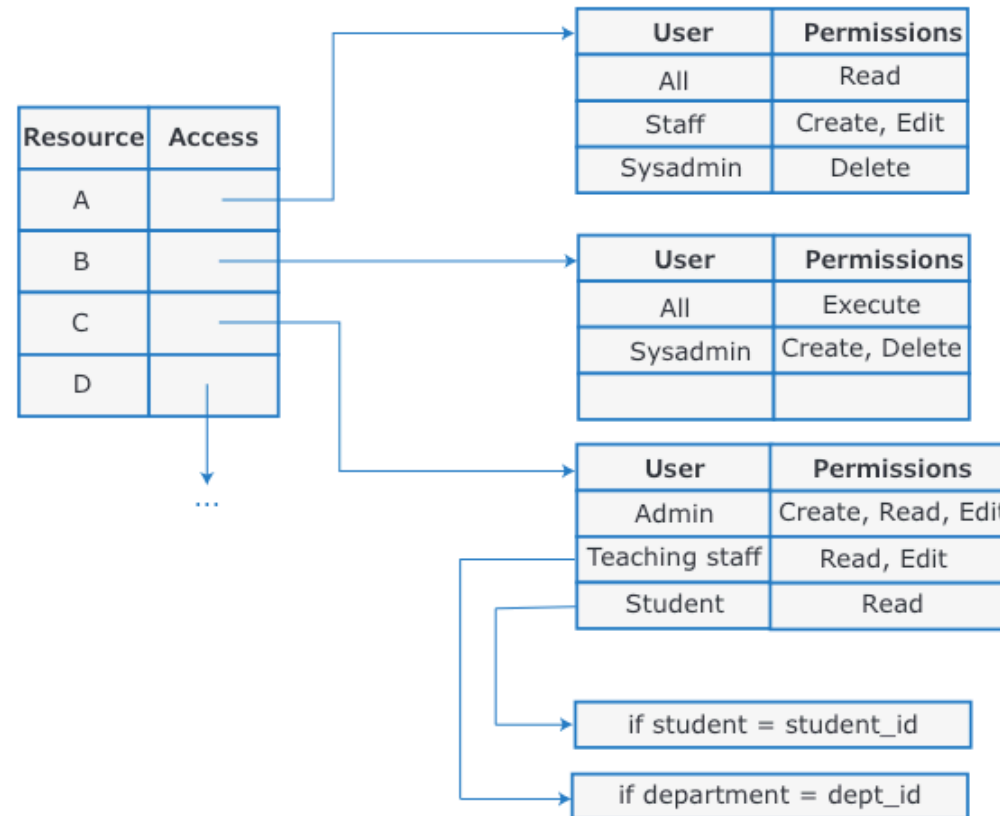
Table 7.3 Weaknesses of password-based authentication

Weakness	Explanation
Insecure passwords	Users choose passwords that are easy to remember. However, it is also easy for attackers to guess or generate these passwords, using either a dictionary or a brute force attack.
Phishing attacks	Users click on an email link that points to a fake site that tries to collect their login and password details.
Password reuse	Users use the same password for several sites. If there is a security breach at one of these sites, attackers then have passwords that they can try on other sites.
Forgotten passwords	Users regularly forget their passwords, so you need to set up a password recovery mechanism to allow these to be reset. This can be a vulnerability if users' credentials have been stolen and attackers use that mechanism to reset their passwords.



... and Authorisation

Figure 7.8 Access control lists



Soc



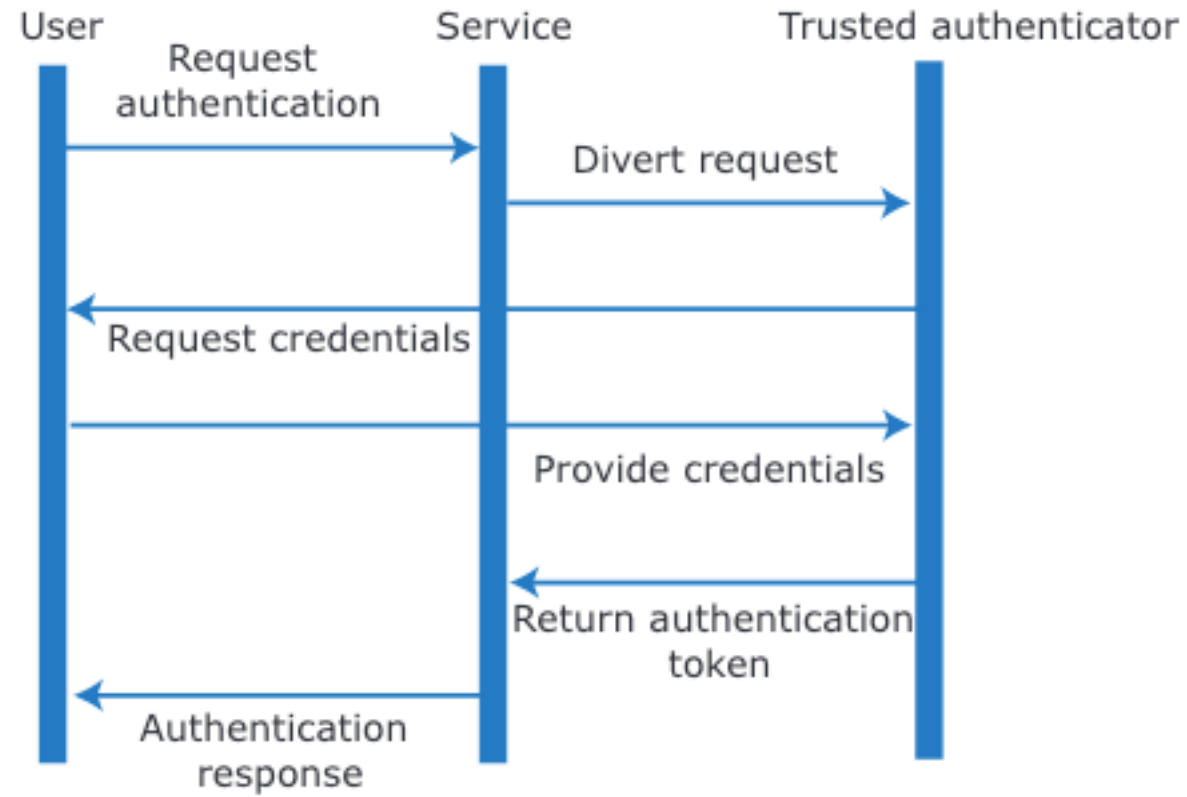
Closing the in
ideally without

- Removing all
- Covering trac
- Bringing the

Defences:
• Training
• MFA
• Antivirus(es)

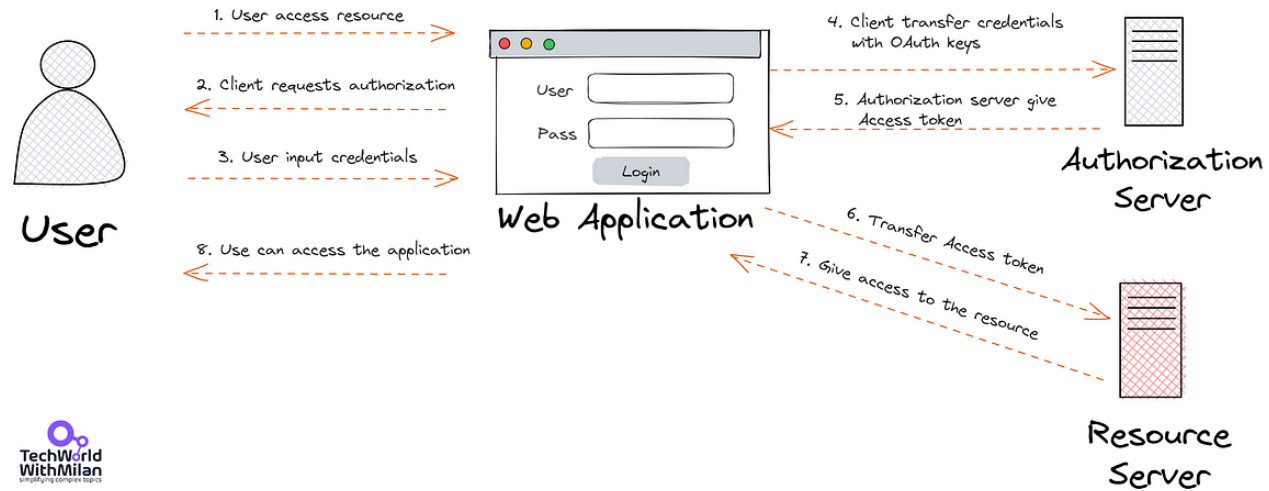
Federated Identity

Figure 7.5 Federated identity



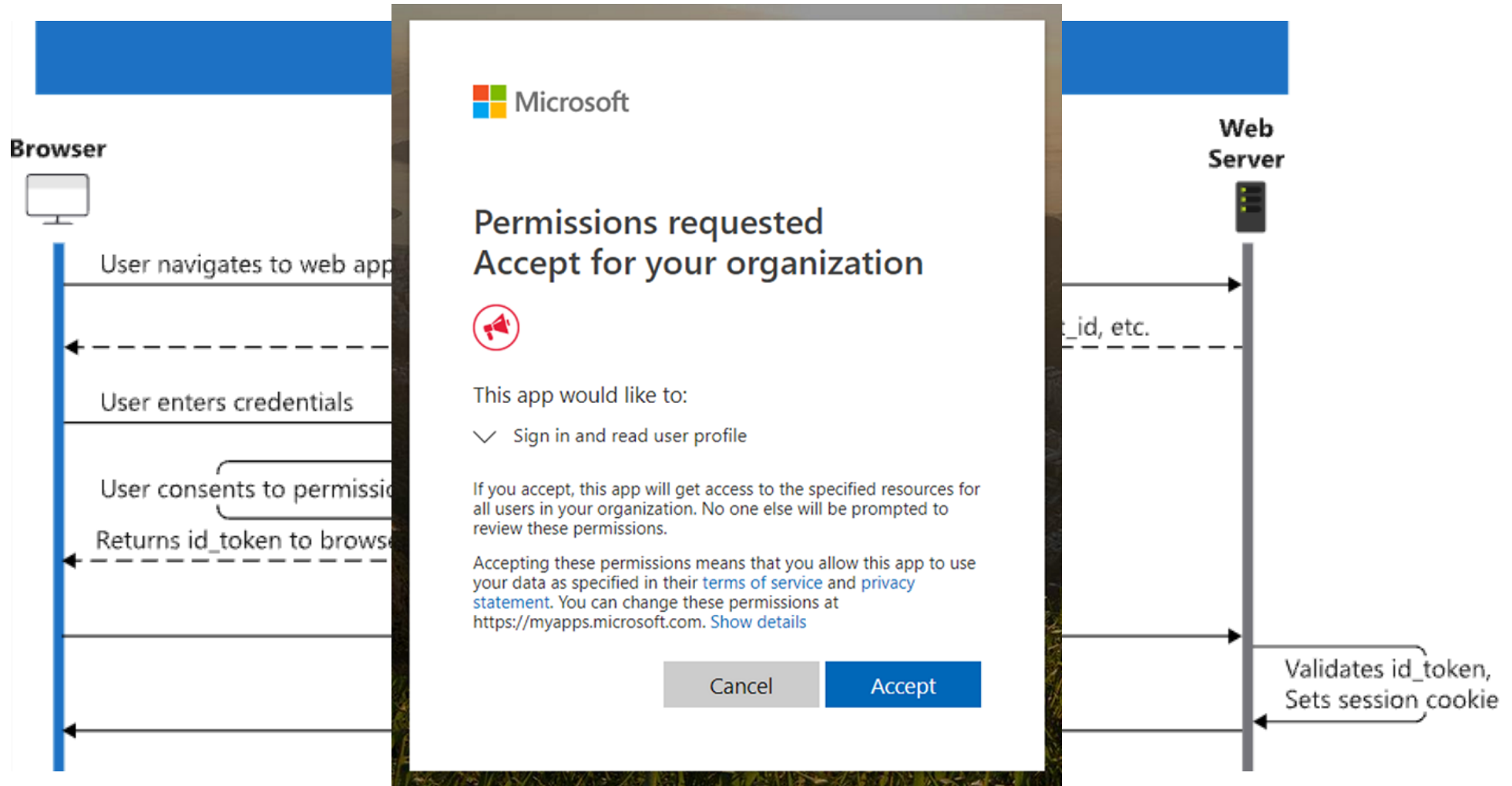
Federated Identity

OAuth 2.0 Flow



OAuth 2.0 provides a "Key" (Access Token). Possession of the key does not prove you are the owner of the house; it just proves you have permission to enter.

Federated Identity



Focus: OAuth 2.0 focuses on authorization (granting access to resources), while OpenID Connect focuses on authentication (verifying user identity).

Tokens: OAuth 2.0 issues access tokens, whereas OpenID Connect issues both access tokens and ID tokens.

Scope: OAuth 2.0 is used for granting access to resources, while OpenID Connect is used for user authentication and obtaining user profile information.



Federated Identity

Sign In

New to SoloLearn? [Create an Account](#)



Sign in with Google



Sign in with Facebook

or



Federated Identity

ROeID
Autentificare

Adresă Email

Parola

[Ai uitat parola?](#)

Autentifică-te

Pentru a crea un cont nou
înregistrează-te folosind aplicația de
mobil



15:51



ROeID

Cerere de autorizare

Nume utilizator:
cristea.rares96@gmail.com
A fost trimisa o cerere de autorizare
pe aplicatia ROeID.

Aprobare in curs



Verificati cererea de autorizare in
aplicatia mobila ROeID



15:51



Autorizează cererea de
autentificare



Ghiseul

IP 80.96.21.160
08.12.2025, 15:51
Bucharest, RO

41

Timp rămas

✓ Autorizează

✗ Refuză

15:52



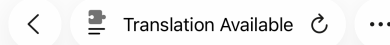
ROeID

Această aplicație cere acces la
următoarele informații:

- prenume
- nume
- nume_prenume
- adresa
- cnp
- email
- telefon
- localitate
- judet
- sector
- serie

Acceptă

Respinge



Privacy

Figure 7.16 Data protection laws





Privacy



Table 7.6 Data protection principles

Data protection principle	Explanation
Awareness and control	Users of your product must be made aware of what data are collected when they are using your product, and must have control over the personal information that you collect from them.
Purpose	You must tell users why data are being collected and you must not use those data for other purposes.
Consent	You must always have the consent of a user before you disclose their data to other people.
Data lifetime	You must not keep data for longer than you need to. If a user deletes an account, you must delete the personal data associated with that account.
Secure storage	You must maintain data securely so that it cannot be tampered with or disclosed to unauthorized people.
Discovery and error correction	You must allow users to find out what personal data you store. You must provide a way for users to correct errors in their personal data.
Location	You must not store data in countries where weaker data protection laws apply unless there is an explicit agreement that the stronger data protection rules will be upheld.





Privacy





Privacy

1. EU Residents have the right to know what you are doing with their data
2. Time for data breach notification is 72 hours.
3. Right to be Forgotten - a user should be able to disappear from all of your data stores.
4. Control over the rights of the transmission of data.



Dark Patterns of Consent

<https://wideangle.co/blog/dark-patterns-examples-of-manipulative-consent-requests>



<https://www.mindk.com/blog/how-to-make-your-software-gdpr-compliant/>



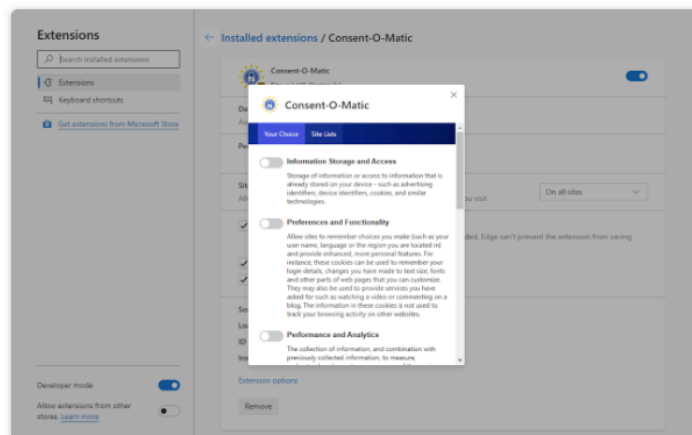
Featured 4.0 ★ (142 ratings)

Extension

Privacy & Security

100,000 users

Remove



Overview

Automatic handling of GDPR consent forms

Cookie pop-ups are designed to be confusing and make you 'agree' to be tracked. This add-on automatically answers consent pop-ups for you, so you can't be manipulated. Set your preferences once, and let the technology do the rest!

This add-on is built and maintained by workers at Aarhus University in Denmark. We are privacy researchers that got tired of seeing how companies violate the EU's General Data Protection Regulation (GDPR). Because the organisations that enforce the GDPR do not have enough resources, we built this add-on to help them out.



Kahoot!



Resources Used

